Improper Input Validation: Repetitive Registration (OWASP Juice Shop)

Severity: Low - Context-dependent

1. Concept Overview

The DRY (Don't Repeat Yourself) principle states that information or logic should have a single authoritative representation wherever possible.
During registration, users enter their password twice:
- **Password:** The actual account password.
- **Repeat Password:** A confirmation value intended to verify that the password was entered correctly.

The application should validate that both values match, including on the server side. The Juice Shop challenge demonstrates what happens when this validation can be bypassed.

2. Vulnerability Identification

The registration form performed password confirmation checks in the user interface, but the server did not properly enforce the same validation.
Using Burp Suite, the registration request could be intercepted and modified before it reached the server.

3. Methodology

- Opened the OWASP Juice Shop registration page.
- Entered the required registration details.
- Configured Burp Suite Proxy to intercept the registration request.
- Submitted the registration form.
- Intercepted the HTTP request in Burp Suite.
- Modified the password and password confirmation values so they were different.
- Forwarded the modified request to the server.
- Observed that the application successfully created the new user account despite the mismatched values.

4. Security Impact

Insufficient server-side validation allows registration requests containing inconsistent password values to be accepted. This demonstrates that client-side validation alone is not sufficient to protect application functionality. An attacker can modify HTTP requests before they reach the server.

5. Remediation

- Validate password and repeat-password values on the server.
- Reject registration requests when the two values do not match.
- Treat client-side validation as a usability feature, not a security control.
- Keep validation rules consistent between the frontend and backend.

6. Result

Successfully completed the Repetitive Registration challenge by intercepting and modifying the registration request using Burp Suite, demonstrating that the server accepted a registration with mismatched password values.

7. Evidence Screenshots

Include screenshots showing:

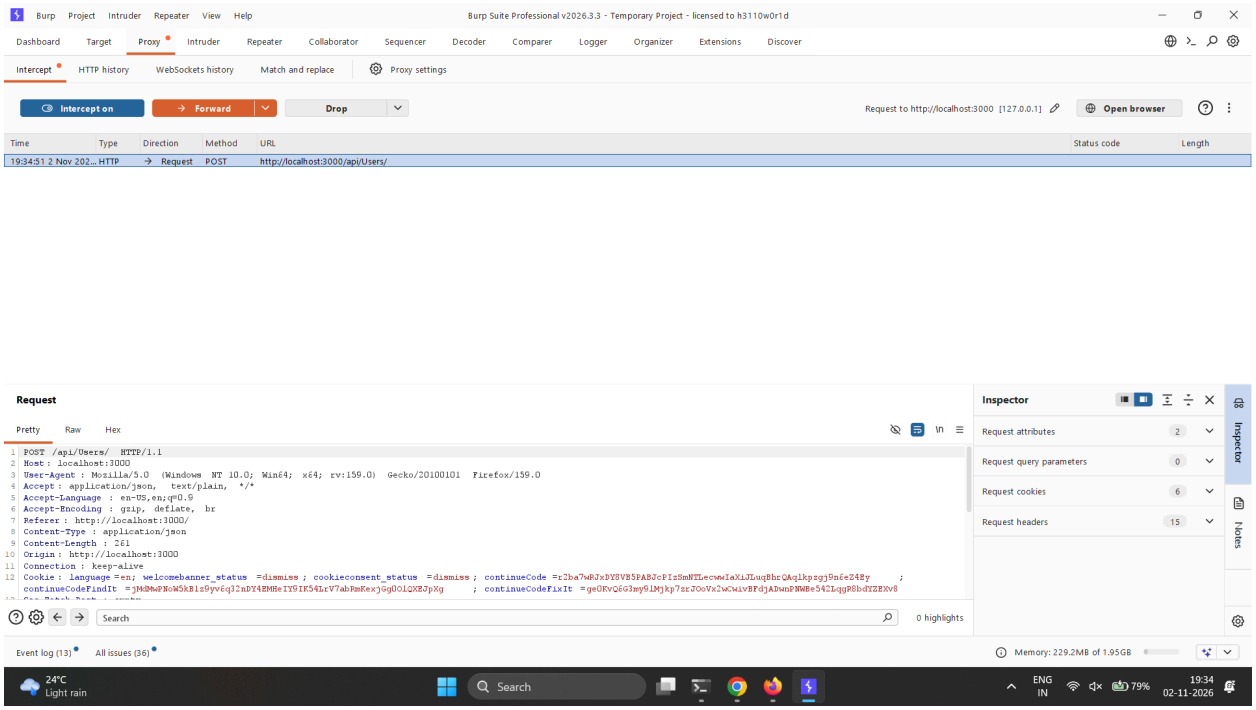


Figure 1: Burp Suite intercepting the registration request.

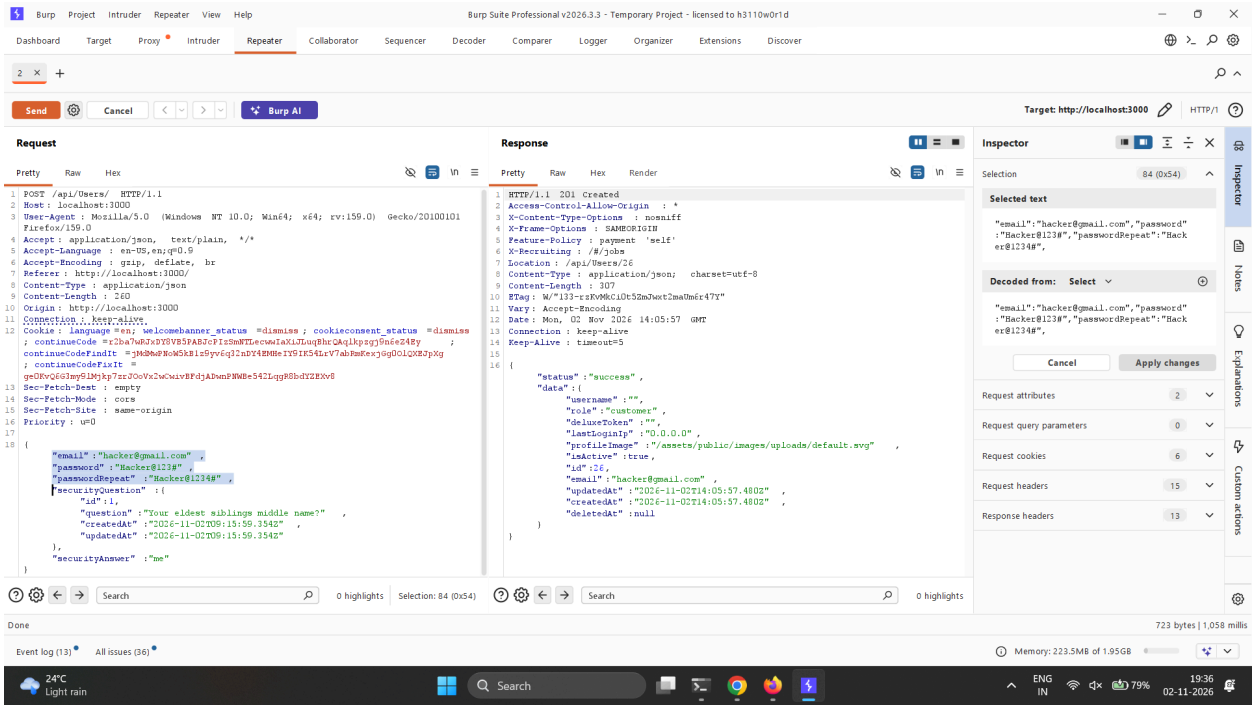


Figure 2: Modified password and confirmation values and forwarded the request.

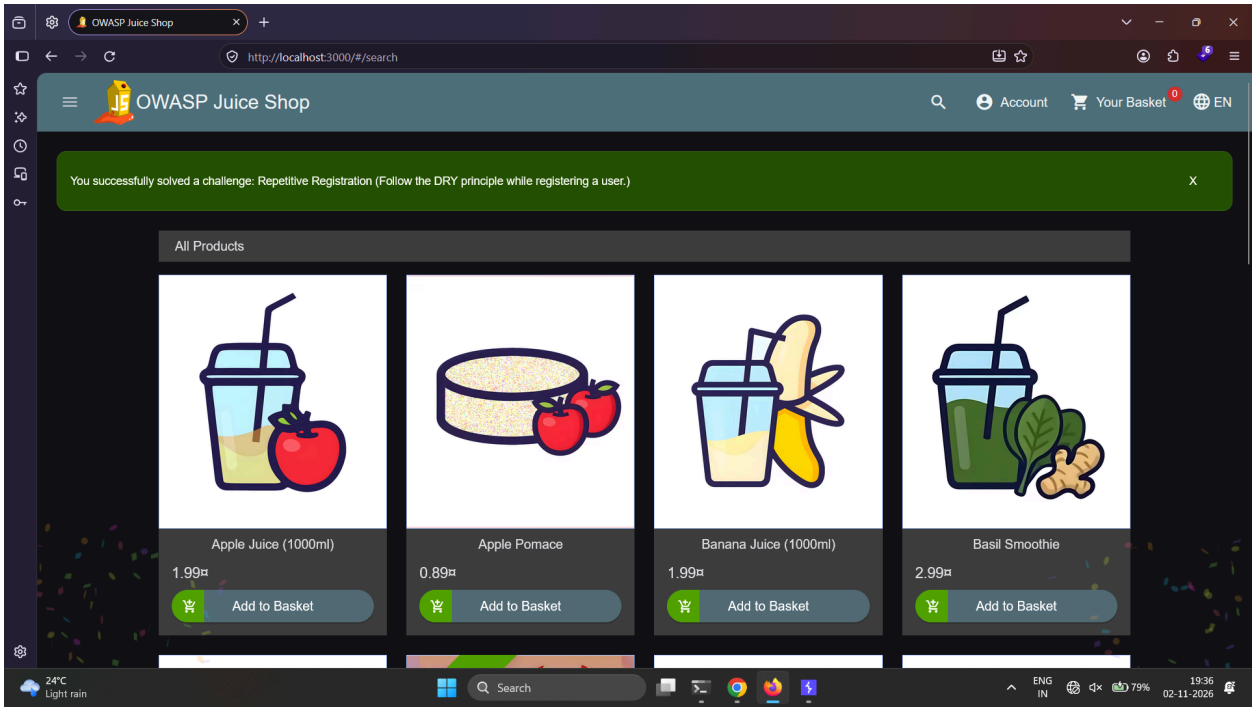


Figure 3: OWASP Juice Shop showing the challenge as completed.

Suggested severity: Low the demonstrated issue allows registration with mismatched password and repeat-password values. By itself, this does not demonstrate account takeover or unauthorized access. Severity could change if further testing identifies a more serious authentication impact.
The important security lesson is that server-side validation must not rely only on the registration form's client-side checks. A user can modify request data before it reaches the server.

8. References

- OWASP Juice Shop – Improper Input Validation
- OWASP Input Validation Cheat Sheet